TECHNICAL WHITE PAPER

Secure Enterprise Mail Migration

A practical framework for moving Zimbra mailboxes to Mailcow

Amar Nath Pandey
Information Security and Penetration Testing

29 October 2026 · Version 1.0

Executive overview

A mail migration affects identity, message delivery, stored data and the tools employees use every day. Copying mailbox contents is only one part of the work. A dependable transition also needs a tested recovery path, clear DNS ownership and evidence that users can send, receive and find their messages.

This paper proposes an operational framework for a Zimbra to Mailcow migration. It covers discovery, staged synchronisation, delivery validation, security controls and service acceptance. The intended readers are infrastructure engineers, security auditors and administrators responsible for enterprise email.

Scope: This is an independently published practitioner guide. It contains no client data, measured migration results or claim of journal review. The checklists describe a proposed approach that teams should adapt and validate in their own environment.

1. Discovery and migration design

Begin with an inventory that the service owner can verify. Record active accounts, aliases, shared access, forwarding rules, quotas and actual storage use. Identify applications, scanners and monitoring systems that send mail. An overlooked application sender can fail even when employee mail works normally.

Decision	Evidence to record
Identity and access	Account mapping, disabled accounts, delegation and administrator ownership
Data coverage	Folders, flags, message dates, contacts, calendars and rules requiring separate handling
Delivery path	MX, A/AAAA and PTR records, SMTP relay, allowed sender identities and outbound connectivity
Recovery	Backup scope, successful restore test, rollback owner and retention window

IMAP synchronisation primarily addresses mail content. Treat calendars, contacts, server rules and delegation as separate migration items unless a tested method covers them. Create a pilot group that includes large mailboxes and users with different clients.

2. Target readiness

Prepare the target hostname, storage, certificates and access restrictions before copying production mail. Keep management access limited to authorised administrators. Test inbound delivery, authenticated submission and IMAP access independently. Confirm the relay accepts the actual sender identities, rather than relying on a successful TCP connection.

Mailcow documents its certificate handling and renewal configuration [1]. Validate the hostname and certificate chain with the clients that users will actually run. Keep secrets out of command history and migration logs. Use temporary migration access only for the approved window, then revoke it.

3. Staged synchronisation and cutover

Use an initial copy while the source remains available, followed by incremental passes. Retain per mailbox logs and a list of exceptions. Investigate authentication failures, server disconnects and inaccessible source messages before treating a run as complete. A lower transfer rate is acceptable when it produces reliable, repeatable results.

Stage	Exit condition
Pilot	Representative users accept mailbox contents, client behaviour and delivery
Initial copy	Every in scope mailbox has a recorded result and exception owner
Final delta	The team reconciles changes made since the initial copy
Delivery switch	DNS and relay changes match the approved plan
Acceptance	Mail flow, access and data checks pass with documented exceptions

Schedule the delivery switch only after the pilot and recovery checks pass. Reduce DNS TTL in advance when the DNS owner permits it. Keep the source intact for the agreed retention period. DNS propagation and messages already queued elsewhere can cause both systems to receive mail during the transition, so define how the team will reconcile that overlap.

Rollback and reconciliation

Agree on rollback triggers before the change window. Examples include widespread authentication failure, sustained outbound rejection or mailbox access loss. Record who can change routing and who can approve a rollback. If users or remote senders have written new messages to the target, reversing MX records alone will not reconcile that data. Preserve it and plan the copy back explicitly.

4. Security validation

Sender identity. SPF authorises hosts for an SMTP envelope or HELO identity [2]. A passing SPF check alone does not authenticate the visible From address. Check alignment when validating the complete sender path.

DMARC. DMARC combines SPF or DKIM authentication with alignment to the author domain and lets domain owners publish handling preferences [3]. Capture actual message headers from each approved sending route. Account for forwarded messages and legitimate third party senders before enforcing a stricter policy.

Transport and access. Check certificate validity, submission authentication, relay restrictions and account access. Test that unauthenticated clients cannot relay to unrelated external destinations. Review administrative access and login failure monitoring. Validate each intended network path rather than assuming one successful connection proves the whole service.

5. Service acceptance

Test	Acceptance evidence
Mailbox integrity	Sample counts plus original dates, attachments, folder paths and flags
Inbound and outbound mail	Tests across independent external providers and application senders
Sender authentication	Headers showing expected SPF, DKIM and DMARC results
User workflows	Webmail, IMAP client, sent items, search, signatures and shared access
Recovery	A completed restore test with the recovery steps recorded

Message totals can differ because of folders, duplicates or source defects. Document the reason for any variance. Use content samples and exception review alongside counts. User acceptance should include search and sent mail, since delivery tests do not reveal those problems.

6. Operational handover

Assign owners for certificate renewal, backups, queue monitoring, disk capacity, updates and security alerts. Record the target configuration and keep the migration exception register with the handover notes. Set a date for removing temporary accounts and retiring the source after the retention period and acceptance approval.

Close the change only when operations can recover the service without relying on the migration engineer. The final record should show what moved, what required separate handling, which tests passed and which limitations remain.

Implementation record template

Record	Required detail
Scope	Account list, exclusions and data types
Recovery evidence	Backup time, restore result and rollback conditions
Change record	Routing changes, owner and timestamps
Exception register	Affected mailbox, issue, evidence and resolution
Acceptance	Test results, user feedback and service owner approval

References

[1] Mailcow documentation: Advanced SSL
https://docs.mailcow.email/post_installation/firststeps-ssl/

[2] RFC 7208: Sender Policy Framework
https://www.rfc-editor.org/info/rfc7208/

[3] RFC 9989: Domain Based Message Authentication, Reporting, and Conformance
https://www.rfc-editor.org/info/rfc9989/

References accessed 29 October 2026. RFC 9989 supersedes RFC 7489. Product behaviour and configuration requirements should be checked against the version deployed.